FINÁLNÍ PROJEKT
č. 2

Tomáš Čáp

ENGETO Testing Akademie
3. dubna 2026

Obsah

ZADÁNÍ 3
TESTOVACÍ SCÉNÁŘE 4
Autentizační a autorizační testy 5
CRUD operace (READ) 6
CRUD operace (CREATE) 7
CRUD operace (UPDATE) 9
CRUD operace (DELETE) 11
Bezpečnostní testy (ukázka) 12
EXEKUCE TESTŮ 13
Testovací prostředí 14
Tabulka výsledků testů (RUN-01) 15
BUG REPORT 16
Bug report (RUN-01) 17
SOUHRN 18

ZADÁNÍ

Cílem finálního projektu je otestovat funkčnost aplikace, která slouží k manipulaci s údaji o studentech. Aplikace poskytuje REST API pro vytváření, mazání a získávání dat o studentech.

Přístupové údaje:

Databáze	**Default scheme**: students **Host**: test-app.engeto.cz **Port**: 5433
REST API REST API dokumentace	https://test-app.engeto.cz/students https://test-app.engeto.cz/docs

TESTOVACÍ SCÉNÁŘE

Funkčnost aplikace byla ověřena pomocí níže definovaných testovacích scénářů; jejich detail je uveden v souboru `details.xlsx` *(list „**testCases**“) v GitHub repozitáři projektu.*

Autentizační a autorizační testy

Test ID	Název testu	Endpoint / metoda	Request (headers + body)	Očekávaný výsledek (status code + response)
TC-01	Login – platné přihlašovací údaje	/login POST	**Headers:** - Content-Type: application/json **Body:** `{ "login": "testing_academy_2026_01_13", "password": "WPrEmzjP9p1rDzCS" }`	**200 OK** **Response:** - obsahuje `accessToken` (string) - `tokenType` = bearer
TC-02	Login – neplatné heslo	/login POST	**Headers:** - Content-Type: application/json **Body:** `{ "login": "testing_academy_2026_01_13", "password": "wrong_password" }`	**401 Unauthorized** **Response:** - autentizace selhala (chyba přihlášení)
TC-03	Login – prázdné tělo požadavku	/login POST	**Headers:** - Content-Type: application/json **Body:** `{ }`	**422 Unprocessable Entity** **Response:** - validační chyba – chybí povinné parametry

CRUD operace (READ)

Test ID	Název testu	Endpoint / metoda	Request (headers + body)	Očekávaný výsledek (status code + response)
TC-04	GET student – platné ID	/students/{id} GET	**Headers:** - Authorization: Bearer `<token>` **Body:** -	**200 OK** **Response:** - obsahuje `id`, `firstName`, `lastName`, `email`, `isEuCitizen`, `numberOfFailedStudies`
TC-05A	GET student – chybějící token	/students/{id} GET	**Headers:** - (prázdné) **Body:** -	**401 Unauthorized** **Response:** - autentizace selhala (chybějící token)
TC-05B	GET student – neplatný token	/students/{id} GET	**Headers:** - Authorization: Bearer `<wrong_token>` **Body:** -	**401 Unauthorized** **Response:** - autentizace selhala (neplatný token)
TC-06	GET student – neexistující ID	/students/9999 GET	**Headers:** - Authorization: Bearer `<token>` **Body:** -	**404 Not Found** **Response:** - objekt nenalezen
TC-07A	GET student – neplatné ID (text)	/students/abc GET	**Headers:** - Authorization: Bearer `<token>` **Body:** -	**422 Unprocessable Entity** **Response:** - validační chyba – neplatné ID
TC-07B	GET student – neplatné ID (záporné číslo)	/students/-1 GET	**Headers:** - Authorization: Bearer `<token>` **Body:** -	**422 Unprocessable Entity** **Response:** - validační chyba – neplatné ID
TC-07C	GET student – neplatné ID (0)	/students/0 GET	**Headers:** - Authorization: Bearer `<token>` **Body:** -	**422 Unprocessable Entity** **Response:** - validační chyba – neplatné ID

CRUD operace (CREATE)

Test ID	Název testu	Endpoint / metoda	Request (headers + body)	Očekávaný výsledek (status code + response)
TC-08	CREATE student – platné údaje	/students POST	**Headers:** - Authorization: Bearer `<token>` - Content-Type: application/json **Body:** `{ "firstName": "Jan", "lastName": "Novak", "email": "jan.novak@example.com", "isEuCitizen": true, "zipCode": "11000", "numberOfFailedStudies": 0 }`	**201 Created** **Response:** - student vytvořen, obsahuje `id`, `firstName`, `lastName`, `email`, `isEuCitizen`, `numberOfFailedStudies`
TC-09	GET student – platné ID (dynamické)	/students/{new_id} GET	**Headers:** - Authorization: Bearer `<token>` **Body:** -	**200 OK** **Response:** - obsahuje `id`, `firstName`, `lastName`, `email`, `isEuCitizen`, `numberOfFailedStudies`
TC-10	CREATE student – duplicitní email	/students POST	**Headers:** - Authorization: Bearer `<token>` - Content-Type: application/json **Body:** `{ "firstName": "Jan", "lastName": "Novak", "email": "jan.novak@example.com", "isEuCitizen": true, "zipCode": "11000", "numberOfFailedStudies": 0 }`	**400 Bad Request** **Response:** - student s tímto emailem již existuje
TC-11	CREATE student – neplatný token	/students POST	**Headers:** - Authorization: Bearer `<wrong_token>` - Content-Type: application/json **Body:** `{ "firstName": "Adam", "lastName": "Malina", "email": "adam.malina@example.com", "isEuCitizen": true, "zipCode": "11000", "numberOfFailedStudies": 0 }`	**401 Unauthorized** **Response:** - autentizace selhala (neplatný token)
TC-12	CREATE student – chybějící `lastName`	/students POST	**Headers:** - Authorization: Bearer `<token>` - Content-Type: application/json **Body:** `{ "firstName": "Kryštof", "email": "krystof.horacek@example.com", "isEuCitizen": true, "zipCode": "11000", "numberOfFailedStudies": 0 }`	**422 Unprocessable Entity** **Response:** - validační chyba – chybí pole `lastName`

TC-13	CREATE student – neplatný formát emailu	/students POST	**Headers:**
			- Authorization: Bearer `<token>`
			- Content-Type: application/json
			Body:
			`{`
			`"firstName": "Jana",`
			`"lastName": "Tichá",`
			`"email": "invalid",`
			`"isEuCitizen": true,`
			`"zipCode": "11000",`
			`"numberOfFailedStudies": 0`
			`}`
				422 Unprocessable Entity
				Response:
				- validační chyba – neplatný formát `email`

CRUD operace (UPDATE)

Test ID	Název testu	Endpoint / metoda	Request (headers + body)	Očekávaný výsledek (status code + response)

TC-14	UPDATE student – existující student	/students/{new_id} PUT	**Headers:**
			- Authorization: Bearer `<token>`
			- Content-Type: application/json
			Body:
			{
			"firstName": "Jan",
			"lastName": "Novak",
			"email": "jan.new@example.com",
			"isEuCitizen": true,
			"zipCode": "11000",
			"numberOfFailedStudies": 0
			}
				200 OK
				Response:
				- student úspěšně aktualizován
				- DB obsahuje nové údaje (SQL)

TC-15	UPDATE student – neplatný token	/students/{new_id} PUT	**Headers:**
			- Authorization: Bearer `<wrong_token>`
			- Content-Type: application/json
			Body:
			{
			"firstName": "Jan",
			"lastName": "Novak",
			"email": "jan.new@example.com",
			"isEuCitizen": true,
			"zipCode": "11000",
			"numberOfFailedStudies": 0
			}
				401 Unauthorized
				Response:
				- autentizace selhala (neplatný token)
				- DB záznam nezměněn (SQL)

TC-16	UPDATE student – neexistující student	/students/9999 PUT	**Headers:**
			- Authorization: Bearer `<token>`
			- Content-Type: application/json
			Body:
			{
			"firstName": "Jan",
			"lastName": "Novak",
			"email": "jan.new@example.com",
			"isEuCitizen": true,
			"zipCode": "11000",
			"numberOfFailedStudies": 0
			}
				404 Not Found
				Response:
				- objekt nenalezen
				- DB záznam nezměněn (SQL)

TC-17	UPDATE student – neplatný formát emailu	/students/{new_id} PUT	**Headers:**
			- Authorization: Bearer `<token>`
			- Content-Type: application/json
			Body:
			{
			"firstName": "Jan",
			"lastName": "Novak",
			"email": "invalid",
			"isEuCitizen": true,
			"zipCode": "11000",
			"numberOfFailedStudies": 0
			}
				422 Unprocessable Entity
				Response:
				- validační chyba – neplatný formát `email`
				- DB záznam nezměněn (SQL)

TC-18	UPDATE student – chybějící pole	/students/{new_id} PUT	**Headers:**
			- Authorization: Bearer `<token>`
			- Content-Type: application/json
			Body:
			{
			"firstName": "Marek"
			}
				422 Unprocessable Entity
				Response:
				- validační chyba – chybí povinná pole
				- DB záznam nezměněn (SQL)

TC-19	UPDATE student – prázdné tělo	/students/{new_id} PUT	**Headers:** - Authorization: Bearer `<token>` - Content-Type: application/json **Body:** { }	**422 Unprocessable Entity** **Response:** - validační chyba – chybí povinná pole - DB záznam nezměněn (SQL)

CRUD operace (DELETE)

Test ID	Název testu	Endpoint / metoda	Request (headers + body)	Očekávaný výsledek (status code + response)
TC-20	DELETE student – existující student	/students/{new_id} DELETE	**Headers:** - Authorization: Bearer `<token>` **Body:** -	**200 OK** **Response:** - student úspěšně smazán - DB záznam odstraněn (SQL)
TC-21	DELETE student – neplatný token	/students/{new_id} DELETE	**Headers:** - Authorization: Bearer `<wrong_token>` **Body:** -	**401 Unauthorized** **Response:** - autentizace selhala (neplatný token) - DB záznam nezměněn (SQL)
TC-22	DELETE student – neexistující student	/students/9999 DELETE	**Headers:** - Authorization: Bearer `<token>` **Body:** -	**404 Not Found** **Response:** - objekt nenalezen
TC-23	DELETE student – neplatné ID	/students/abc DELETE	**Headers:** - Authorization: Bearer `<token>` **Body:** -	**422 Unprocessable Entity** **Response:** - validační chyba – neplatné ID

Bezpečnostní testy (ukázka)

Test ID	Název testu	Endpoint / metoda	Request (headers + body)	Očekávaný výsledek (status code + response)

TC-24	SQL injection[1)]	/students POST	**Headers:**
			- Authorization: Bearer `<token>`
			- Content-Type: application/json
			Body:
			`{`
			`"firstName": "' OR 1=1 --",`
			`"lastName": "Test",`
			`"email": "test@test.com",`
			`"isEuCitizen": true,`
			`"zipCode": "11000",`
			`"numberOfFailedStudies": 0`
			`}`
				422 Unprocessable Entity
				Response:
				- validační chyba – neprovedena SQL injekce
				- DB neprovedeno (SQL)

TC-25	Neplatný JSON formát[2)]	/students POST	**Headers:**
			- Authorization: Bearer `<token>`
			- Content-Type: application/json
			Body:
			`{`
			`firstName: "Jan",`
			`"lastName": "Novak",`
			`"email": "test@test.com",`
			`"isEuCitizen": true,`
			`"zipCode": "11000",`
			`"numberOfFailedStudies": 0`
			`}`
				422 Unprocessable Entity
				Response:
				- validační chyba – neplatný JSON
				- DB záznam nevytvořen (SQL)

[1)] Minimalizuje riziko neoprávněného přístupu k databázi a úniku či manipulace s daty.“
[2)] Minimalizuje možnost DoS útoků a úniků informací.

EXEKUCE TESTŮ

Testovací scénáře byly provedeny s cílem ověřit funkčnost API, správnou validaci vstupů, autentizaci a autorizaci uživatelů a bezpečnost systému.

Základní údaje:

Tester	Tomáš Čáp
Datum exekuce	2026-03-31
Run ID / Běh testů	RUN-01

Každý test byl exekuován manuálně pomocí nástroje Postman, výsledky byly zaznamenány v Excelu a doplněny ověřením dat přímo v databázi prostřednictvím SQL dotazů.

Detailní informace o testovacím prostředí a záznam výsledků testů (včetně struktury SQL dotazů) jsou uvedeny v souboru `details.xlsx` *(list „**info**“, resp. **„testResults**“) v GitHub repozitáři projektu.*

Testovací prostředí

Operační systém	Windows 11 (22H2)
Webový prohlížeč	Microsoft Edge v146.0
API klient	Postman v12.4.2
Databázový nástroj	DBeaver v24.3.4.0
Správa testů	Microsoft Excel v16.0.10417

Tabulka výsledků testů (RUN-01)

Test-ID	Název testu	Oček. / Skut. kód	Ověření v DB	Výsledek	Bug ID
TC-01	Login – platné údaje	200 / 200	—	PASS	—
TC-02	Login – neplatné heslo	401 / 401	—	PASS	—
TC-03	Login – prázdné tělo	422 / 422	—	PASS	—
TC-04	GET student – platné ID	200 / 200	OK	PASS	—
TC-05A	GET student – chybějící token	401 / 403	—	FAIL	BUG-01
TC-05B	GET student – neplatný token	401 / 401	—	PASS	—
TC-06	GET student – neexistující ID	404 / 500	—	FAIL	BUG-02
TC-07A	GET student – neplatné ID (text)	422 / 422	—	PASS	—
TC-07B	GET student – neplatné ID (záporné)	422 / 500	—	FAIL	BUG-03
TC-07C	GET student – neplatné ID (0)	422 / 500	—	FAIL	BUG-04
TC-08	CREATE student – platné údaje	201 / 201	NOK	FAIL	BUG-05
TC-09	GET student – dynamické ID	200 / 200	—	PASS	—
TC-10	CREATE student – duplicitní email	400 / 400	OK	PASS	—
TC-11	CREATE student – neplatný token	401 / 401	OK	PASS	—
TC-12	CREATE student – chybějící lastName	422 / 201	NOK	FAIL	BUG-06
TC-13	CREATE student – neplatný email	422 / 500	NOK	FAIL	BUG-07
TC-14	UPDATE student – existující	200 / 200	NOK	FAIL	BUG-08
TC-15	UPDATE student – neplatný token	401 / 401	OK	PASS	—
TC-16	UPDATE student – neexistující	404 / 404	OK	PASS	—
TC-17	UPDATE student – neplatný email	422 / 200	NOK	FAIL	BUG-09
TC-18	UPDATE student – chybějící pole	422 / 200	NOK	FAIL	BUG-10
TC-19	UPDATE student – prázdné tělo	422 / 422	OK	PASS	—
TC-20	DELETE student – existující	200 / 200	NOK	FAIL	BUG-11
TC-21	DELETE student – neplatný token	401 / 401	OK	PASS	—
TC-22	DELETE student – neexistující	404 / 500	OK	FAIL	BUG-12
TC-23	DELETE student – neplatné ID	422 / 422	OK	PASS	—
TC-24	SQL injection	422 / 200	NOK	FAIL	BUG-13
TC-25	Neplatný JSON	422 / 422	OK	PASS	—

BUG REPORT

Na základě provedených testovacích scénářů byly identifikovány níže uvedené chyby aplikace. Detailní popis jednotlivých problémů a jejich reprodukce je k dispozici v přiloženém souboru `details.xlsx` *(list „**bugReport**“) v GitHub repozitáři projektu.*

Bug report (RUN-01)

Stupnicé pravděpodobnosti/závažnosti: 1 – nízká, 2 – střední, 3 – vysoká.
Riziko lze následně odhadnout jako součin pravděpodobnosti a závažnosti.

Bug ID	Pravdě-podobnost	Závažnost	Test ID	Nápravné opatření
BUG-01	2	2	TC-05A	Sjednotit autentizační logiku a vracet správný HTTP kód 401 dle specifikace.
BUG-02	3	3	TC-06	Ošetřit neexistující zdroje a vracet 404 místo obecné chyby serveru.
BUG-03	2	2	TC-07B	Zavést validaci vstupních parametrů (ID ≥ 1) na úrovni API.
BUG-04	2	2	TC-07C	Doplnit validační pravidla pro hraniční hodnoty vstupů (např. ID = 0).
BUG-05	2	1	TC-08	Zajistit konzistenci ukládání dat (persistovat všechna pole, nemodifikovat vstupy bez důvodu).
BUG-06	3	3	TC-12	Definovat povinná pole ve specifikaci a validovat je na backendu.
BUG-07	2	2	TC-13	Implementovat validaci formátu emailu a vracet 422 místo 500.
BUG-08	3	3	TC-14	Opravit logiku update operace tak, aby nedocházelo k nechtěné změně dat.
BUG-09	2	2	TC-17	Zavést validační pravidla pro email při UPDATE operaci.
BUG-10	2	1	TC-18	Respektovat semantiku HTTP metod (PUT = full update, případně použít PATCH).
BUG-11	3	3	TC-20	Opravit implementaci DELETE tak, aby skutečně docházelo k odstranění záznamu z DB.
BUG-12	3	3	TC-22	Ošetřit neexistující zdroje správným HTTP kódem 404.
BUG-13	3	3	TC-24	Implementovat ochranu proti SQL injection (validace vstupů, parametrizované dotazy).

SOUHRN

*Během testování bylo provedeno celkem **28 testovacích případů**, z nichž **13 skončilo neúspěšně (FAIL)**.*

***Významná část chyb spadá do kategorie vysoké a kritické závažnosti.** Nejzávažnější zjištění zahrnují zejména nefunkční operaci DELETE (data nejsou fyzicky odstraněna z databáze), chybné ukládání hodnoty `isEuCitizen` v rámci metody PUT, příp. zranitelnost vůči SQL injection (nebylo součástí zadání). Tyto chyby je nutné řešit s nejvyšší prioritou před nasazením systému do produkčního prostředí.*

*Další významnou skupinu tvoří **chyby spojené s nedostatečnou validací vstupů a nesprávným používáním HTTP stavových kódů**. Tyto nedostatky snižují spolehlivost API, komplikují jeho integraci s klientskými aplikacemi a mohou vést k nepředvídatelnému chování systému. Z dlouhodobého hlediska představují zvýšené náklady na údržbu a vyšší riziko vzniku dalších chyb.*

*Z pohledu pravděpodobnosti výskytu lze většinu identifikovaných problémů označit jako **středně až vysoce pravděpodobné**, jelikož se týkají základních funkčních scénářů (CRUD operace, validace vstupů, autentizace). To znamená, že jejich dopad na koncové uživatele i navazující systémy by byl v reálném provozu významný.*

Doporučení:

Před nasazením do produkce je nezbytné:

- *odstranit všechny chyby s kritickou a vysokou závažností,*
- *sjednotit validační a autentizační mechanismy,*
- *zajistit konzistentní používání HTTP status kódů dle specifikace,*
- *event. posílit bezpečnostní opatření (zejména ochranu proti injection útokům – nebylo v zadání).*

Celkově lze kvalitu testovaného API hodnotit jako nedostatečnou pro produkční nasazení, přičemž hlavní rizika spočívají v oblasti konzistence dat a spolehlivosti rozhraní (příp. bezpečnosti).

Závěr

Testování prokázalo nedostatky jak ve funkční logice, tak v oblasti validace a bezpečnosti, což potvrzuje potřebu důsledného testování před nasazením do produkčního prostředí.